JÖNKÖPING UNIVERSITY

JÖNKÖPING UNIVERSITY

Systemadministration - Windows

2024

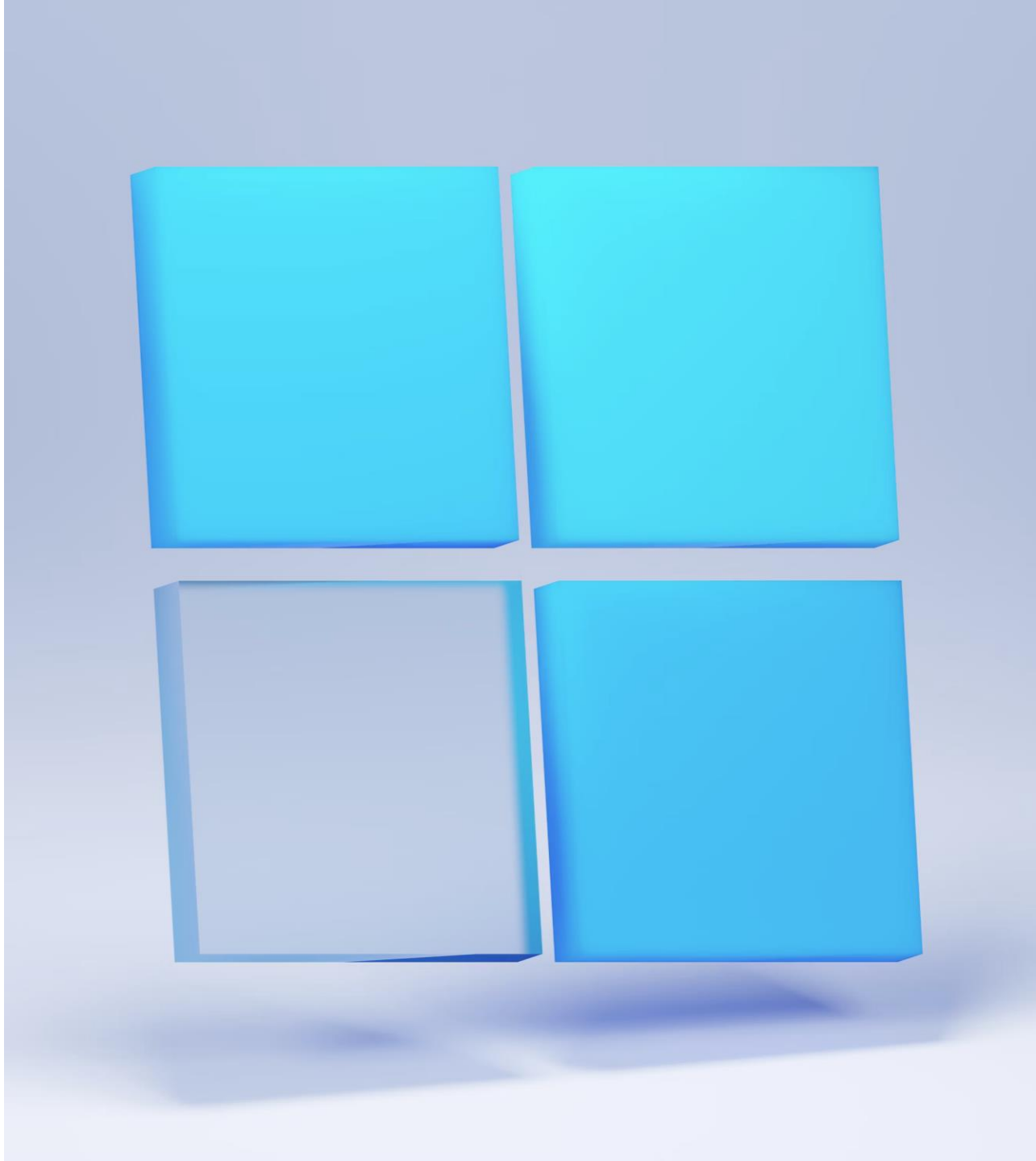
2024-04-24

Agenda

- Vecka 17
  - Introduktion Entra ID & Microsoft 365
  - Laboration: Entra ID & Microsoft 365
- Vecka 18
  - Fortsättning Microsoft 365, Introduktion Modern Enhetshantering, Säkerhet i Microsoft 365
  - Laboration: Microsoft Intune, Microsoft Defender XDR
- Vecka 19
  - Modern Enhetshantering, Säkerhet i Microsoft 365
  - Laboration: Fortsättning Microsoft Intune, Microsoft Defender XDR
- Vecka 20
  - Övervakning, Patch-hantering, Event-hantering, Omvärldsbevakning
  - Laboration: Förvaltning

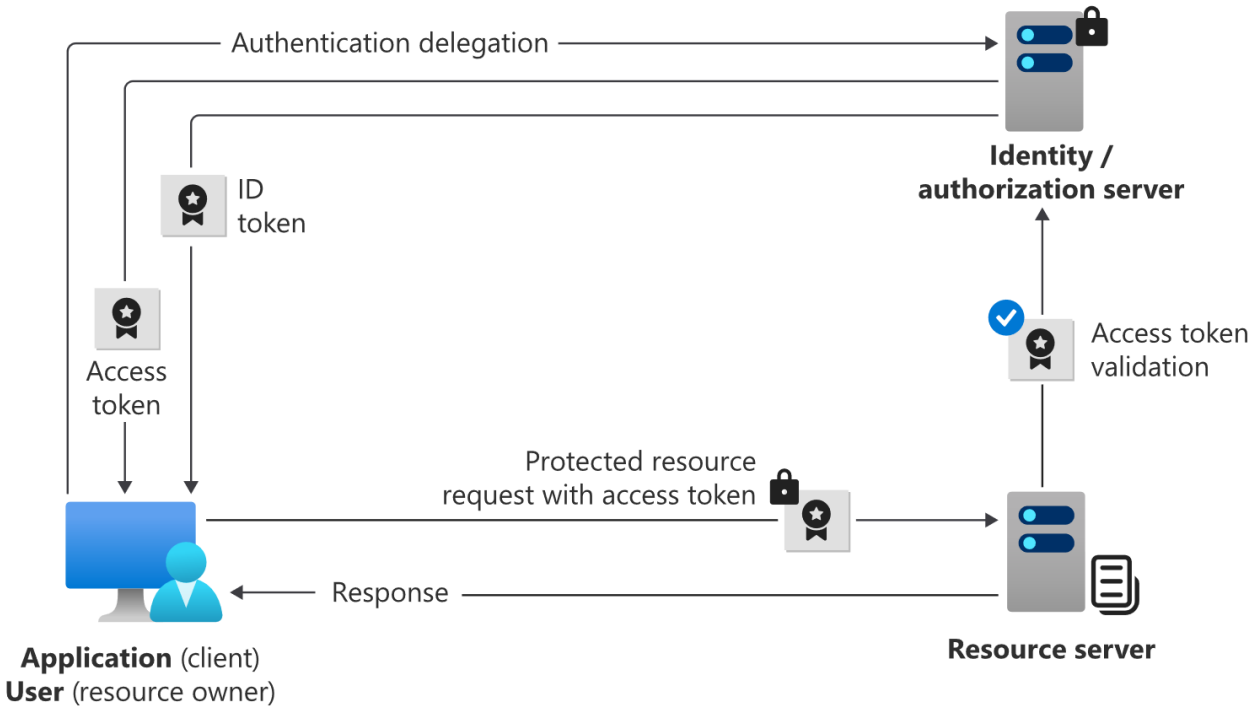
Innehåll

- IAM
- Active Directory
- Entra ID (Azure Active Directory)
- Conditional Access
- Microsoft 365



Identity and Access Management (IAM)

- Principen om hur vi verifierar att rätt identiteter har åtkomst till rätt resurser
- Resurser kan betyda System, Applikationer, andra identitieter, Data etc.
- Kan separeras inom:
  - User Acces & Privileged Access



User Access

- Primärt verifiera att endast behörig personal kommer åt rätt data
- Appliceringsområden:
  - Lönesystem, Affärssytem, Filserver, Sharepoint, Teams, OneDrive, Email

Authentication

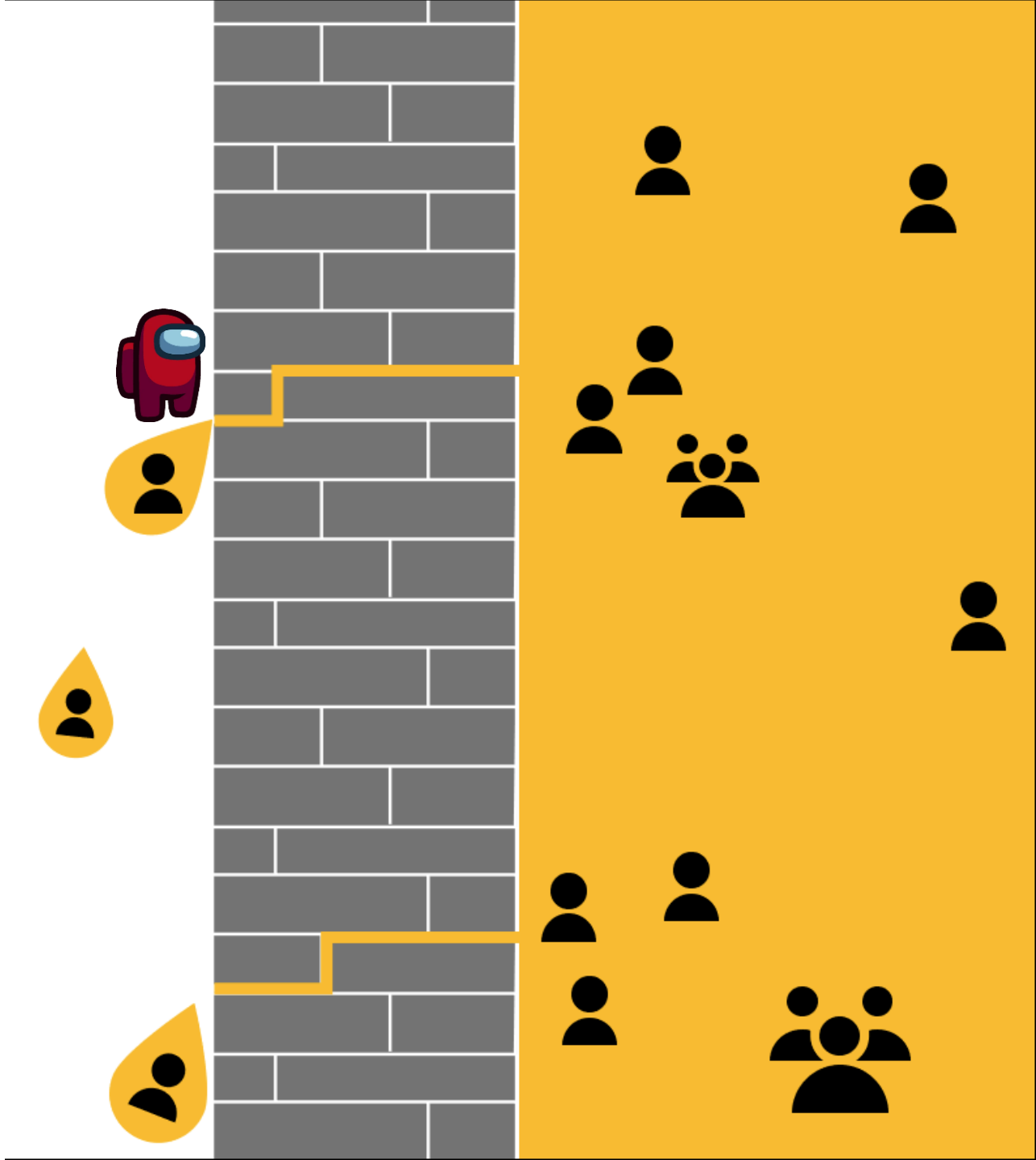
Confirms users are who they say they are

Authorization

Validates users have permission to complete the attempted action

Privileged Access

- Skydda våra resurser från hotaktörer
- Bestämmer vilka identiteter som har behörighet att göra förändringar i en IT-miljö
- Felaktig Privileged Access implementation är något av de mest förekommande i samband med dataintrång



Privileged Access Strategy

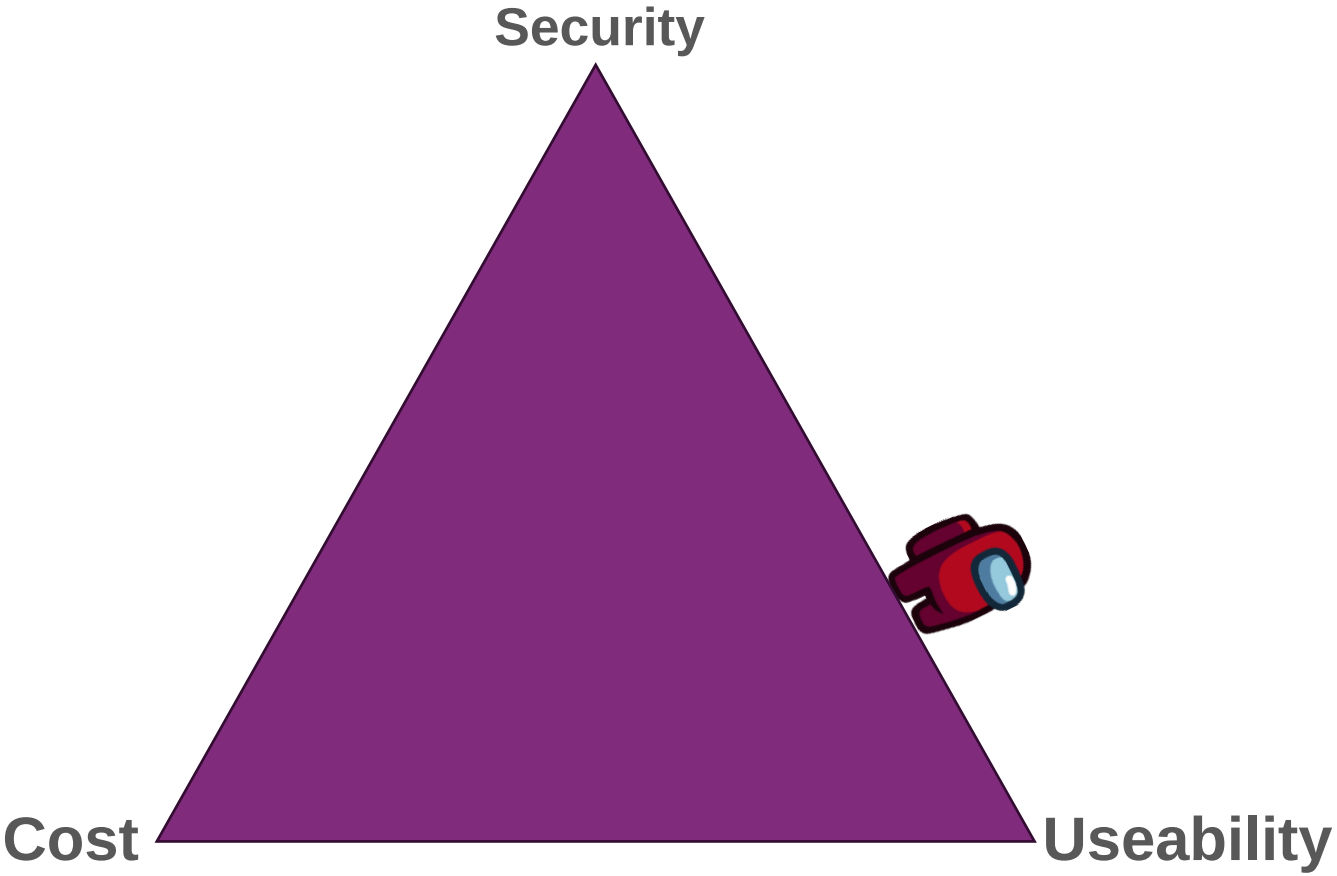
- En Privileged Access strategy beskriver hur vi säkerställer känslig åtkomst i vår IT-miljö
- Bör innehåll:
  - Hur kommer vi åt känsliga resurser?
  - Vilka identiteter får komma åt känsliga resurser?
  - Vad får en identitet göra?
  - Under vilka omständigheter får en identitet komma åt resurser?

	Enterprise Security	Specialized Security	Privileged Security
	Baseline security for assets + starting point for higher security	Enhanced security profile for higher value assets	Strongest security for highest impact assets and accounts
Device Physical device initiating session	Enterprise Device	Specialized Device	**Privileged Access Workstation (PAW)**
Account with access to resources	Enterprise Account	Specialized Account	**Privileged Account**
Intermediary Remote Access / Admin Broker	Enterprise Intermediary	Specialized Intermediary	**Privileged Intermediary**
Interface Controlling resource access	Enterprise Interface	Specialized Interface	**Privileged Interface**

Session

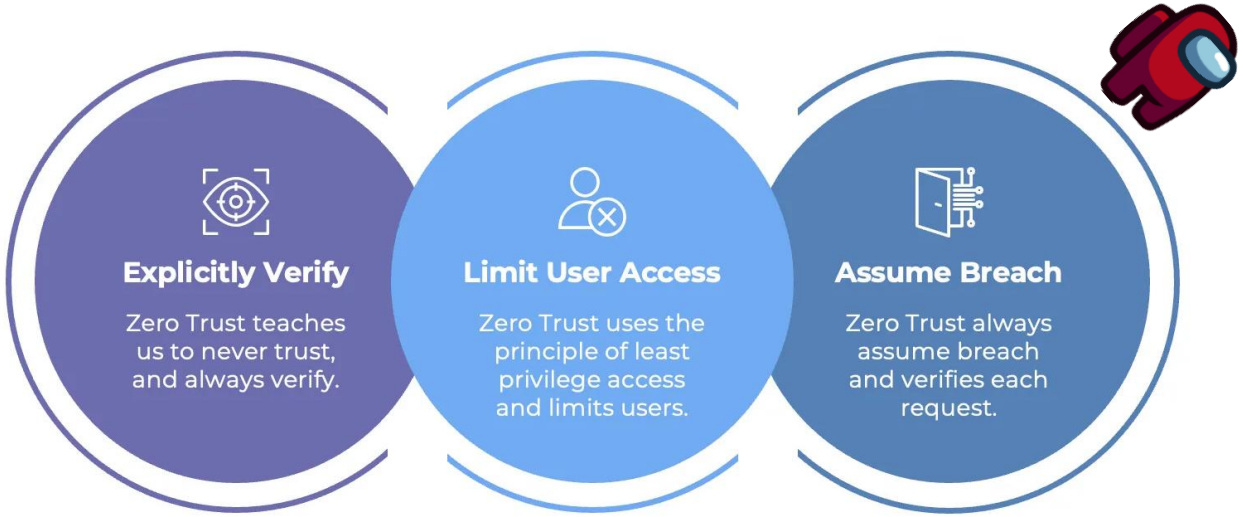
Privileged Access Strategy

- En för komplex strategi blir ofta för kostsam och svår att använda
- En bra strategi skall vara användbar och säker och kunna underhållas



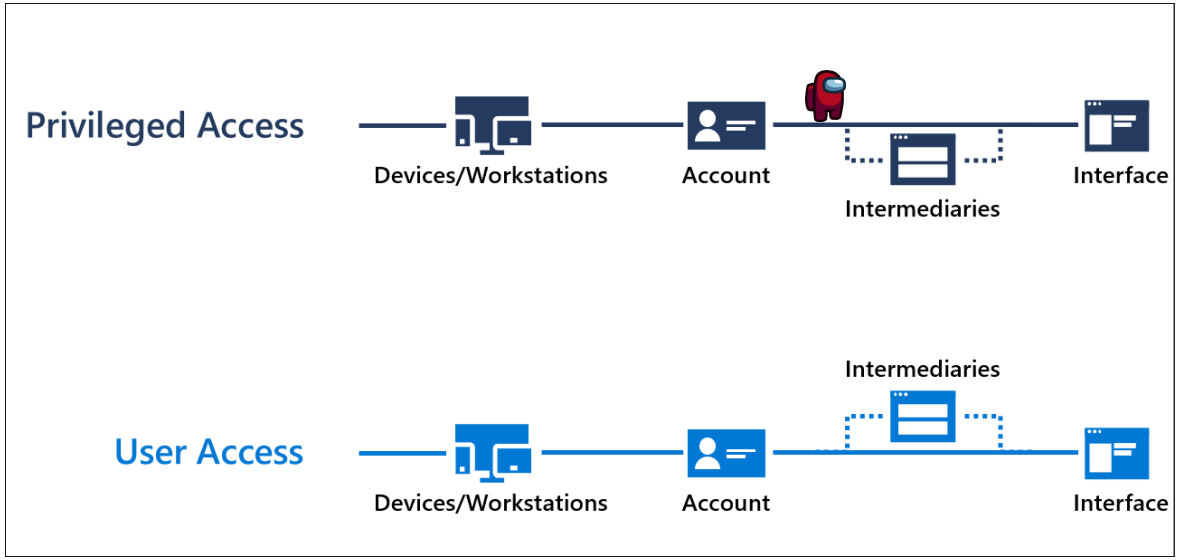
Privileged Access Strategy

- Best Practice för en Privileged Access Strategy är inte en färdig lösning utan handlar om att kombinera tekniker och metodik för att uppnå hög säkerhet
  - Principle of Least Privileges
  - Just-In-Time
  - Assume Breach

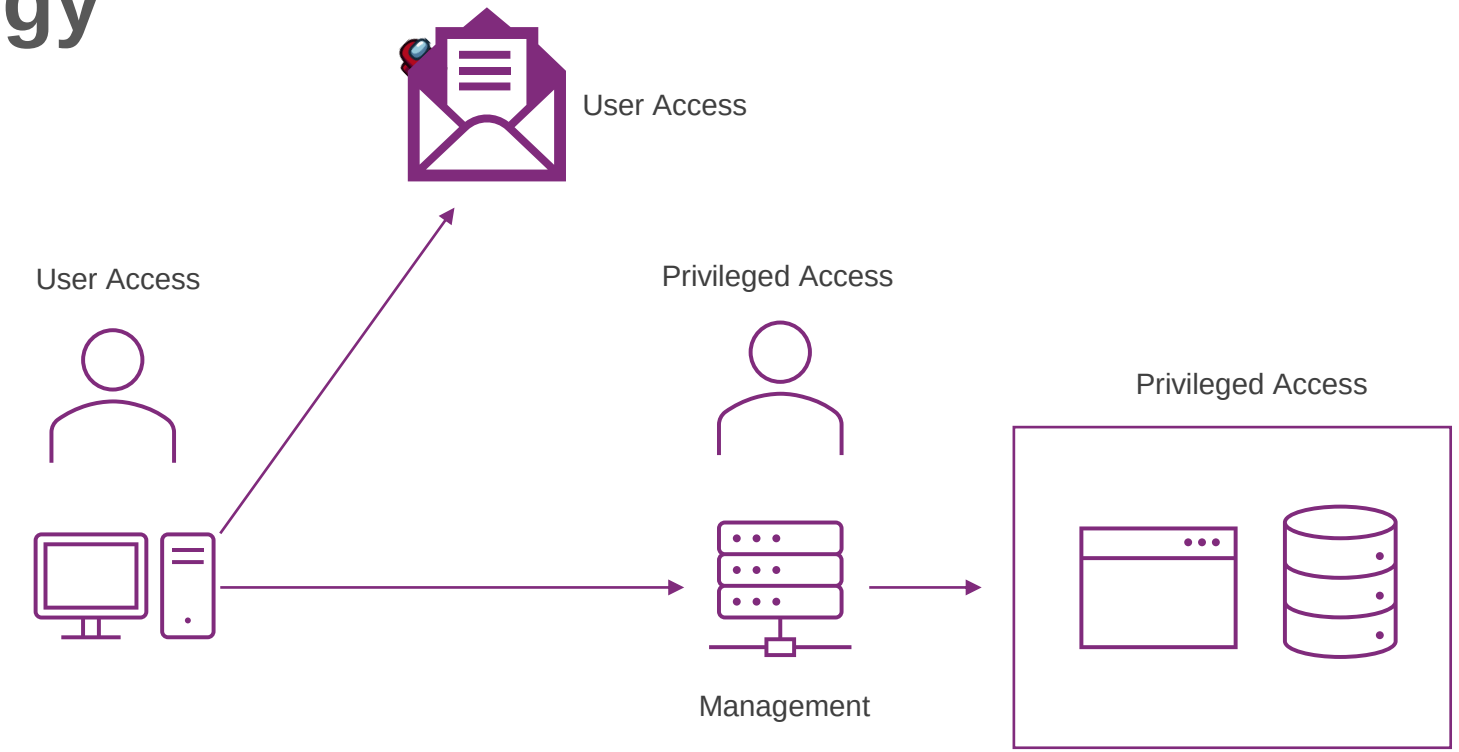


Privileged Access Strategy

- Modern Privileged Access separerar går ut på att helt separera privilegierade konton med användarkonton
  - Ett konto som används för mail, kollaboration skall aldrig ha behörigheter
  - Privileged Access skall helst vara en stängd loop
- Den strategi man väljer måste också gå att underhålla



Privileged Access Strategy



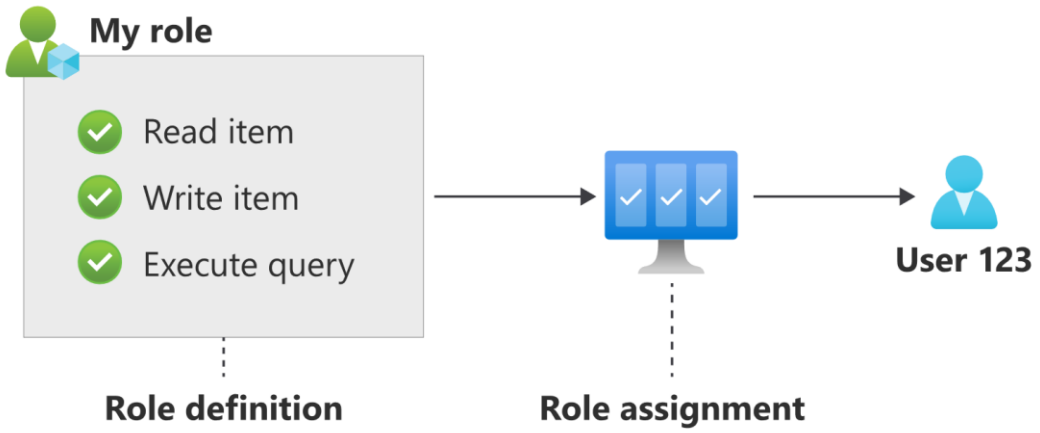
Active Directory

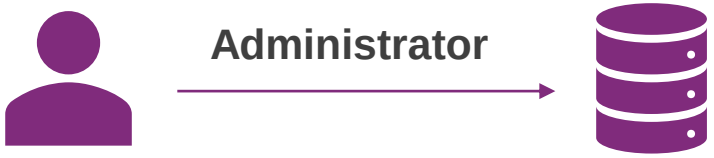
- Active Directory är den mest förekommande identitetsbasen idag
- Behörigheter för att administrera On-Premise Windows miljöer
- Felkonfigurerad behörighetsstruktur leder till stora säkerhetsrisker
- Använder ”*discretionary access control*”

Microsoft
Active Directory

RBAC vs DAC

- RBAC
  - En roll har fördefinierade behörigheter
  - En identitet tilldelas en roll
- DAC
  - En individ tilldelas behörighet på ett en resurs eller ett objekt





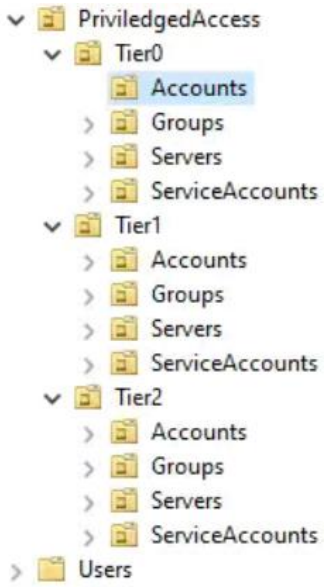
Active Directory

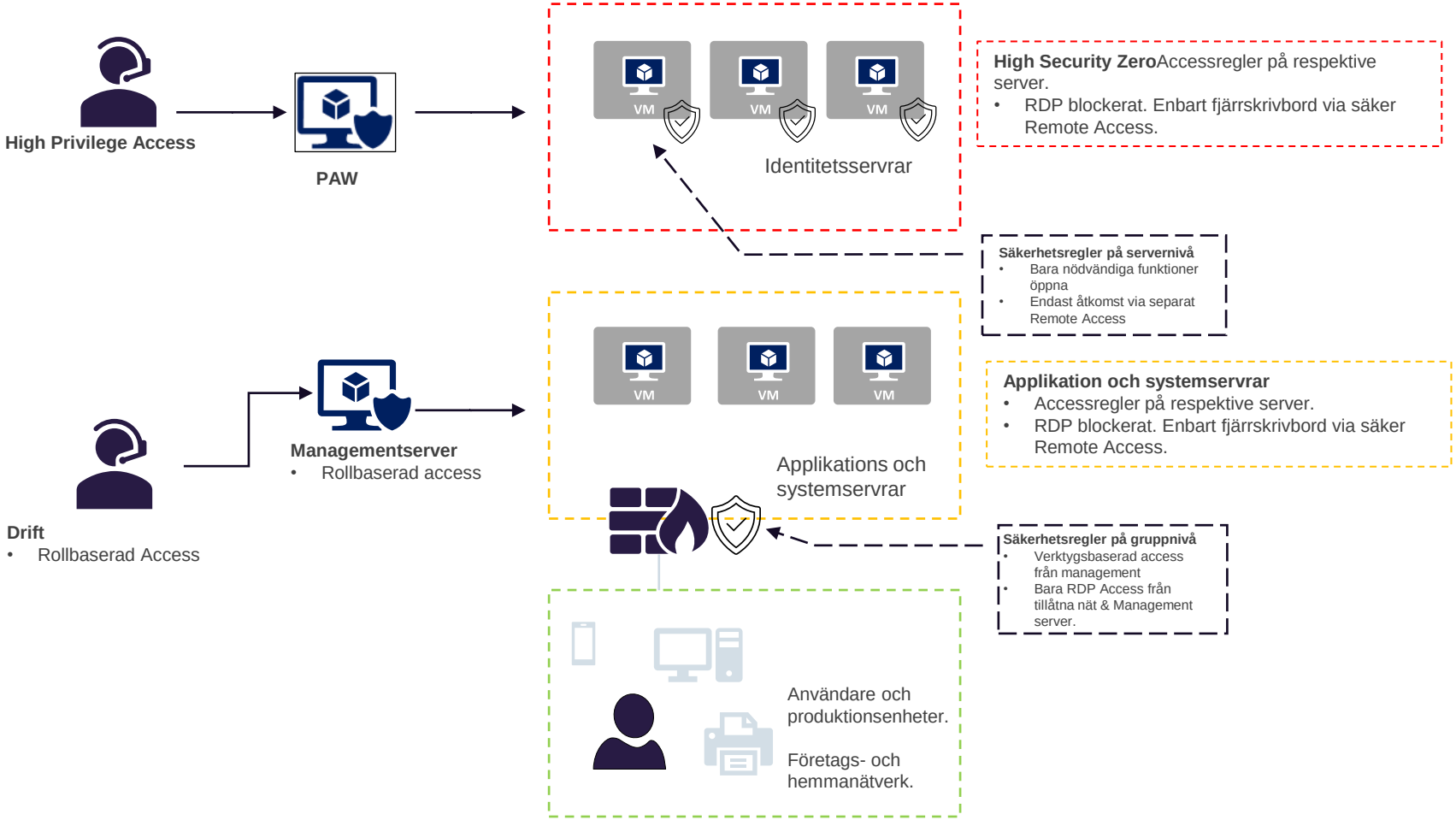
- Viktiga grupper & begrepp
  - Local Users & Groups
  - Local Administrator
  - Domain Administrators
  - Enterprise Administrators
  - Schema Administrators

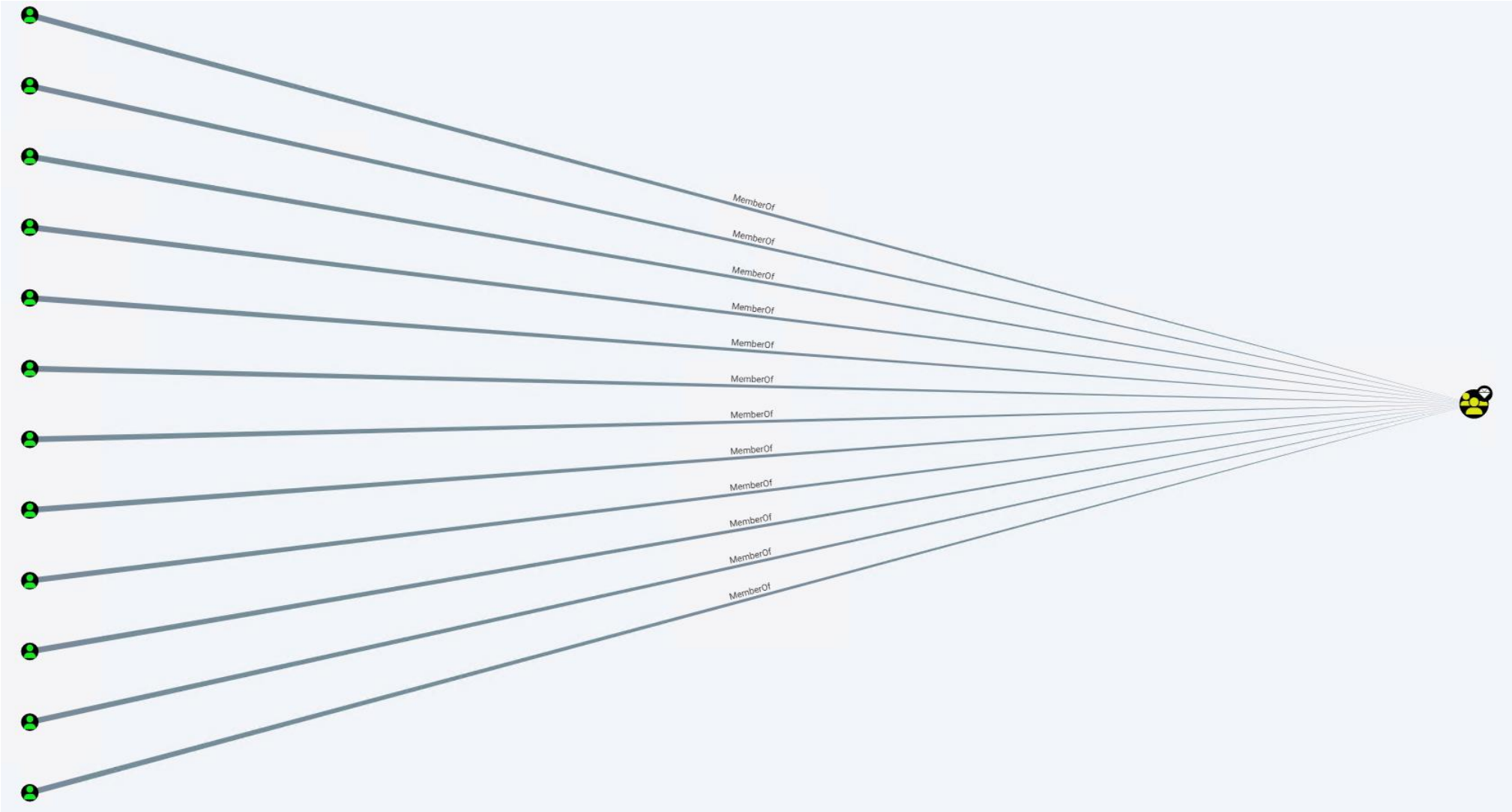
Microsoft
Active Directory

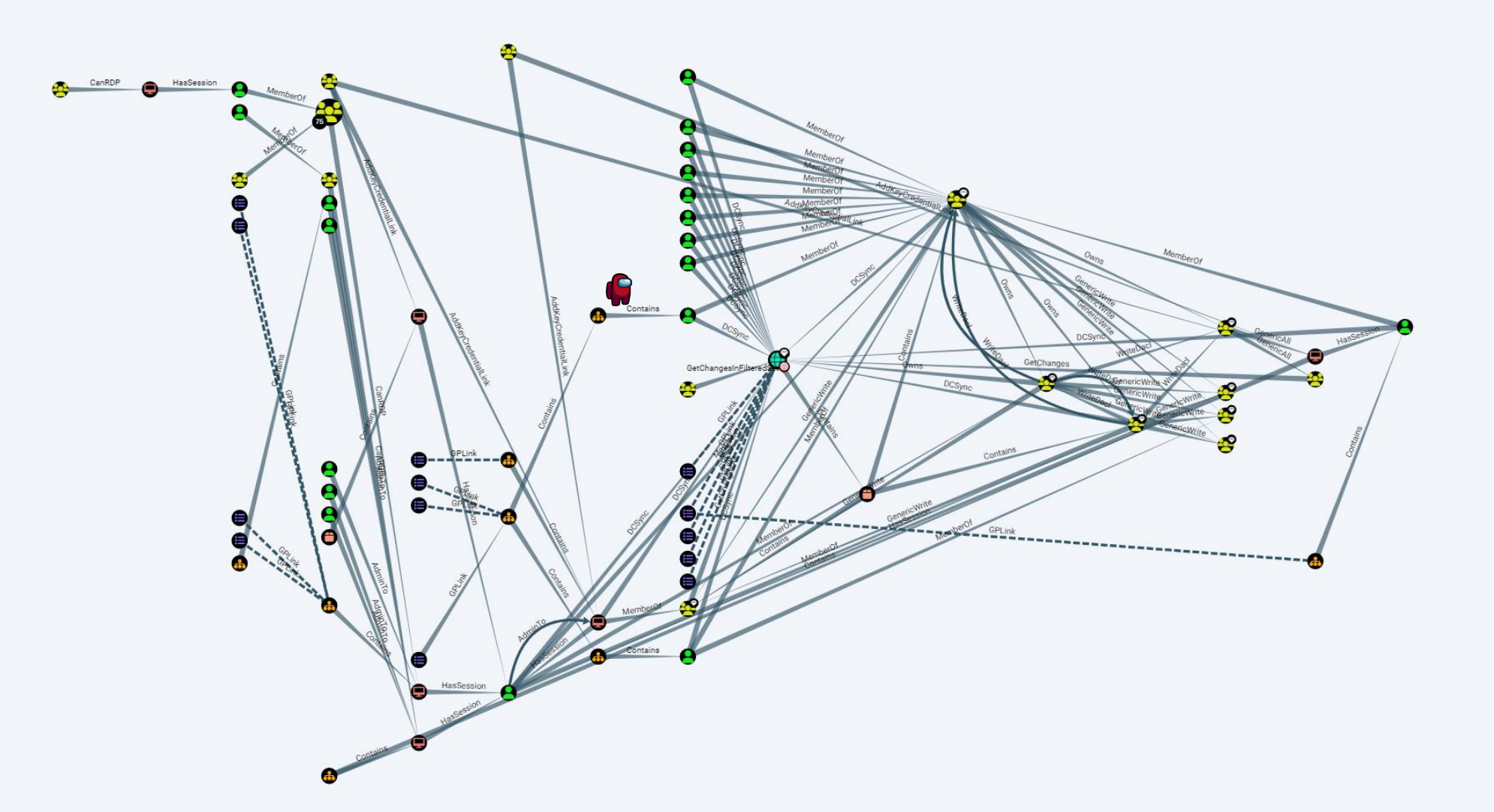
Active Directory Behörighetsstruktur

- Behörigheter i Active Directory ärvs i Organizational Units
- Best Practice är att skapa grupper med höga privilegier högst upp
- Undvik att skapa grupper i grupper eller att delegera behörigheter för en unik identitet



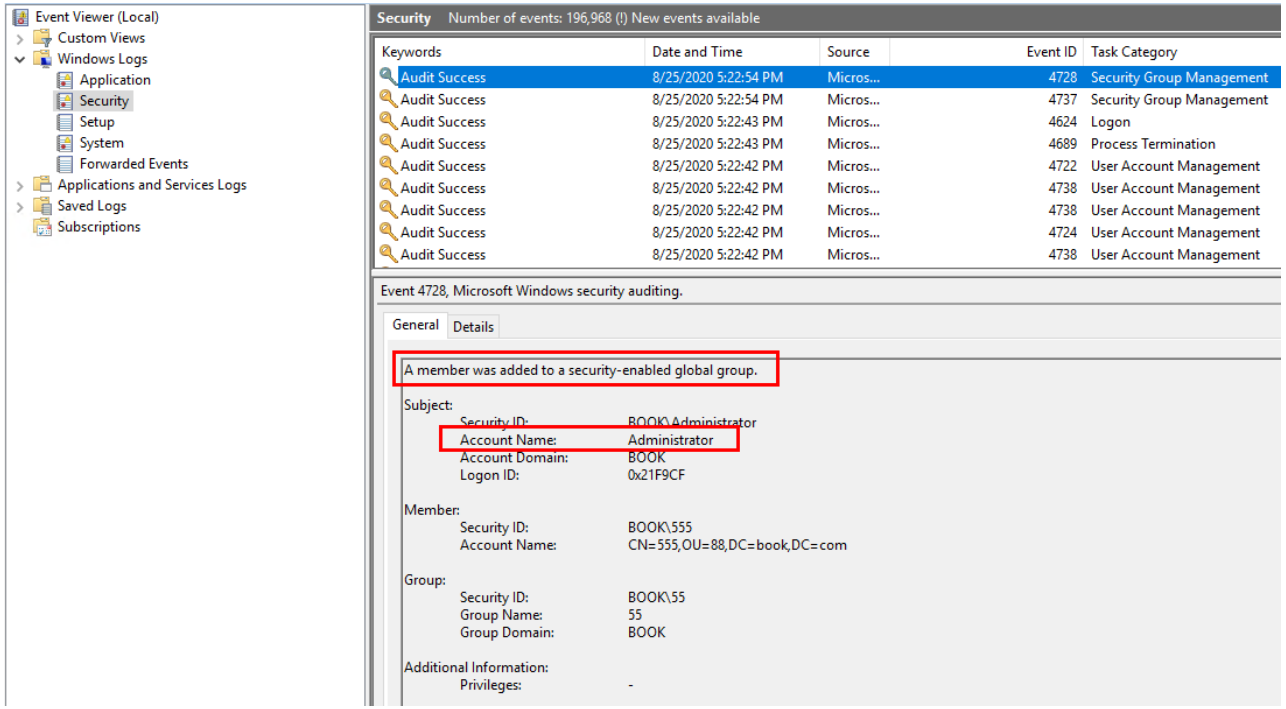

High Privilege Access
PAW
VM
VM
VM
Identitetsservrar
High Security ZeroAccessregler på respektive server.
• RDP blockerat. Enbart fjärrskrivbord via säker Remote Access.
Säkerhetsregler på servernivå
• Bara nödvändiga funktioner öppna
• Endast åtkomst via separat Remote Access
Drift
• Rollbaserad Access
Managementserver
• Rollbaserad access
VM
VM
VM
Applikations och systemservrar
Applikation och systemservrar
• Accessregler på respektive server.
• RDP blockerat. Enbart fjärrskrivbord via säker Remote Access.
Säkerhetsregler på gruppnivå
• Verktygsbaserad access från management
• Bara RDP Access från tillåtna nät & Management server.
Användare och produktionsenheter.
Företags- och hemmanätverk.


MemberOf
MemberOf
MemberOf
MemberOf
MemberOf
MemberOf
MemberOf
MemberOf
MemberOf
MemberOf
MemberOf
MemberOf


CanRDP
HasSession
MemberOf
76
AddKeyCredentialLink
Contains
GPLink
DCSync
GetChangesInFilteredSet
Owns
GenericWrite
WriteDacl
GetChanges
GenericAll
AdminTo
CanPSRemoteTo
HasSession

Active Directory Autentisering

- Information om inloggningar och autentisering för Active Directory finns som standard i Security Log i Event Viewer på en Domänkontrollant
- Best Practice är att exportera viktiga loggar som exempelvis Security



Microsoft 365

- Microsofts moln-baserad SaaS-plattform.
  - Innehåller allt från produktivitet & samarbete till säkerhet
  - Också känt som Office 365 / O365 / M365
- Exempel på produkter som tillhör Microsoft 365:
  - OneDrive, Teams, Sharepoint, Exchange, Intune, Microsoft Defender, Power Automate
- Ersätter många av de produkter som tidigare var server installationer

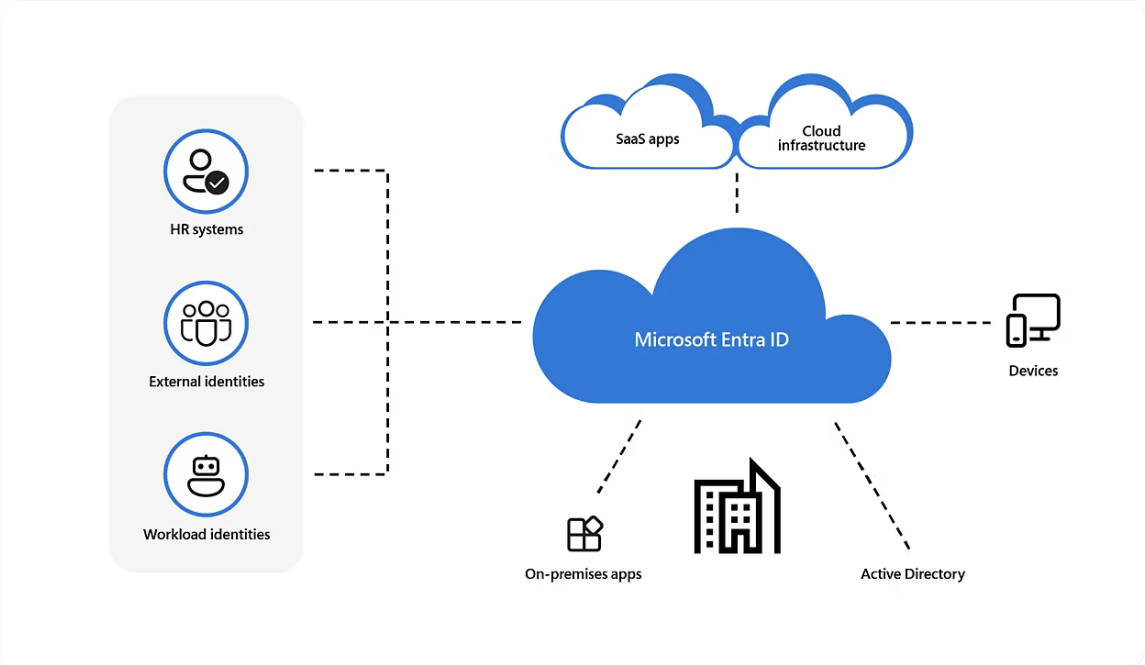
Microsoft 365

Microsoft 365

- Varje Microsoft 365 uppsättning består av en *Tenant*
  - En verksamhet har typiskt 1 Tenant
  - En Tenant kopplas ihop med företagets domän
    - Som standard får varje Tenant ”namn.onmicrosoft.com”
- Varje Microsoft 365 Tenant får också tillgång till Microsofts IaaS & PaaS plattform: Microsoft Azure
- En Microsoft 365 Tenant innehåller identitetsbasen i Microsofts Moln

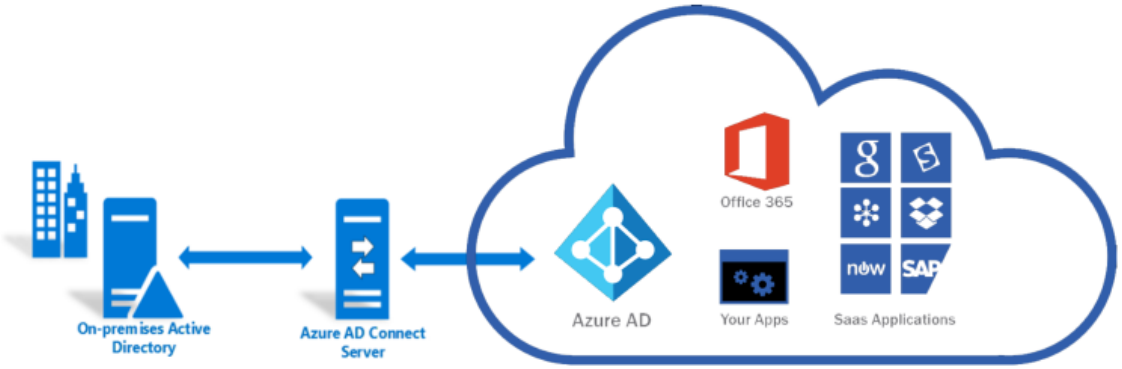
Entra ID

- Entra ID är identitetsbasen för Microsofts moln, samtliga tjänster inklusive Microsoft Azure autentiserar mot Entra ID
  - Tidigare känt som Azure Active Directory
- Samma principer för IAM gäller i Entra ID som i Active Directory
- Entra ID går att integrera mot tredje-parts tjänster



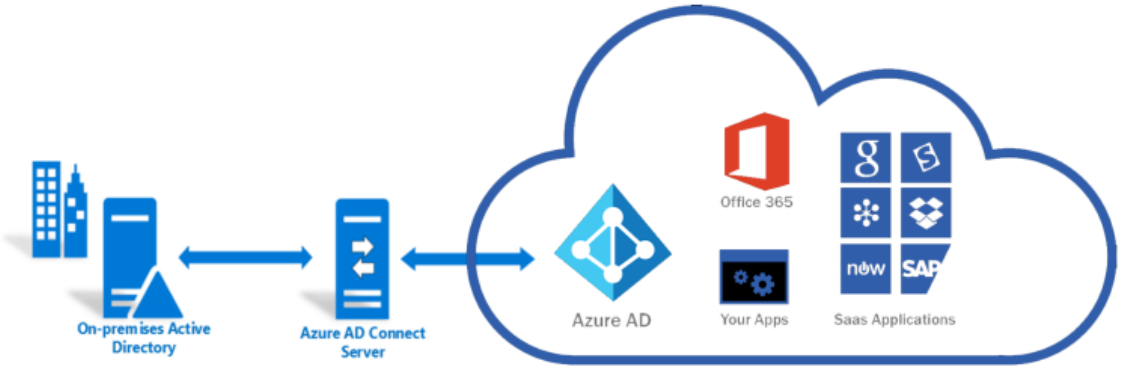
Azure AD Connect

- En identitet måste ha en s.k *Source of Identity*, en Identitet i Microsoft 365 kan ha antingen Active Directory eller Entra ID
- Detta uppnår vi genom att synkronisera användare från Active Directory till Entra ID



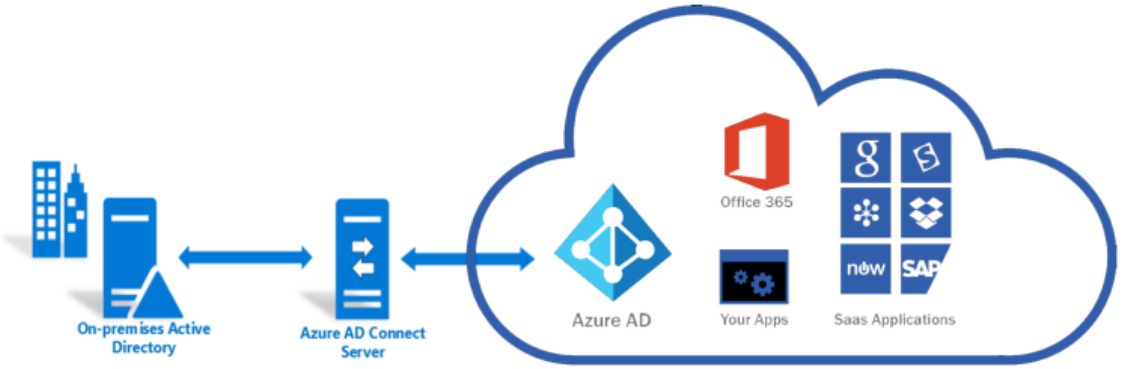
Azure AD Connect

- Detta behöver vi göra när vi vill använda samma identitet för att komma åt resurser On-Premise som vi använder för att nyttja tjänster i Microsoft 365.
  - Fördelar med detta är att vi kan logga in på vår dator, vårt affärssystem och mailklient med samma konto
- Förändringar på en identitet måste ske hos Source of Identity



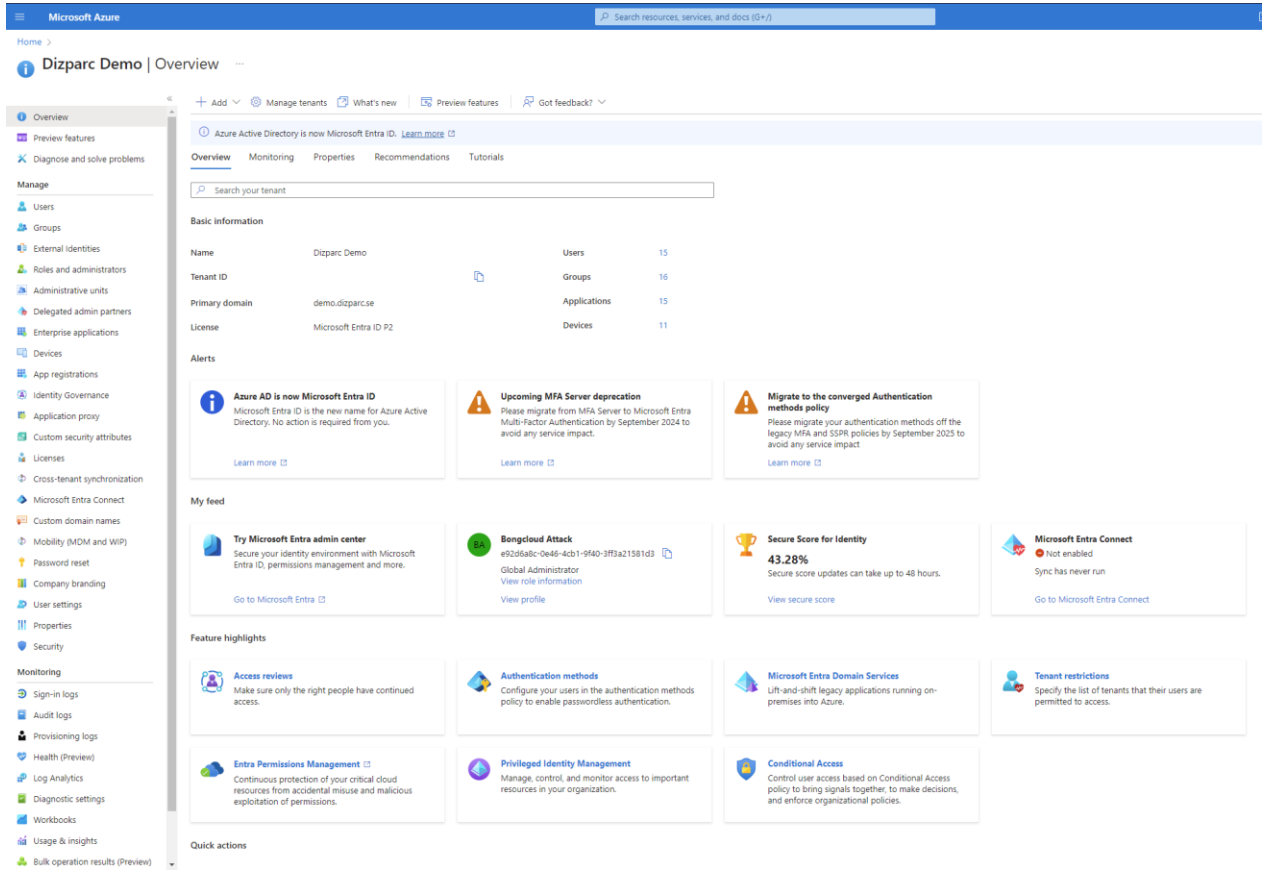
Azure AD Connect

- Azure AD Connect är en applikation som installeras på en server i IT-miljön
- Applikationen kopplas ihop med en Microsoft 365 Tenant
- Azure AD Connect synkroniserar sedan valda object och egenskaper till Microsoft 365
- Många Synkroniserade Miljöer har fortfarande en hybrid-exchange



Entra ID

- Entra ID är en simplare identitetshantering än Active Directory
- Behörigheter i Entra ID sker enligt RBAC modellen
- Enligt Best Practice skall vi undvika att synkronisera konton med Privileged Access



Entra ID
Autentisering

- Information om inloggningar och autentisering för Entra ID finns direkt i Entra ID portalen
- Som standard sparas loggar i 30 dagar
- Best Practice är att utöka hur länge loggar sparas

JÖNKÖPING UNIVERSITY

Date : **Last 7 days** | Show dates as : **Local** | Add filters

User sign-ins (interactive) | User sign-ins (non-interactive)

Date	Request ID	User	Application	Status	IP address	Location	Conditional Acc...	Authentication requirement
4/19/2024, 4:24:55 PM	6b47a95d-9be2-47b0-8db1-74fec16faf00	Bongcloud Attack	Azure Portal	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 4:24:43 PM	c6ed3f18-8e92-40f8-80a7-8944683e6c00	Bongcloud Attack	Office 365 SharePoint Online	Interrupted	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Multifactor authentication
4/19/2024, 11:47:36 AM	6b5cdbef-bb97-444f-b5fd-dccf0f995900	Bongcloud Attack	Office 365 SharePoint Online	Interrupted	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Multifactor authentication
4/19/2024, 11:47:36 AM	b444791d-f54b-4032-ad4b-3502c6b94f00	Bongcloud Attack	Office 365 SharePoint Online	Interrupted	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Multifactor authentication
4/19/2024, 10:46:02 AM	e6f2ca37-4163-44e5-ac65-972a4f4fa000	Bongcloud Attack	Office365 Shell WCSS-Client	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:46:02 AM	3ef5139e-07fc-4b45-b4ec-94d55d059c00	Bongcloud Attack	Office365 Shell WCSS-Client	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:46:02 AM	68be6f8b-4b19-4c45-b0c3-cb1fb28bac00	Bongcloud Attack	Office365 Shell WCSS-Client	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:45:52 AM	4a5bc6d0-4d6c-445f-98d1-94bc4f09a700	Bongcloud Attack	Microsoft 365 Security and Compliance Center	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:36:21 AM	0910d222-5781-454e-a5d2-928f7af0a800	Phil Jones	Office 365 Exchange Online	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Success	Multifactor authentication
4/19/2024, 10:35:26 AM	5b2bab41-2114-4060-990d-8e40d5695800	Bongcloud Attack	Azure Portal	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:02:56 AM	060a31b3-cc6a-437c-9338-8277df177c00	Bongcloud Attack	Microsoft 365 Security and Compliance Center	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:02:53 AM	41dd8f69-5ffa-4f33-b055-41a524f05900	Bongcloud Attack	Azure Portal	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:02:45 AM	36be7efa-ebd5-4777-9eb9-7393817daa00	Bongcloud Attack	Azure Portal	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 10:02:43 AM	41dd8f69-5ffa-4f33-b055-41a5d6ed5900	Bongcloud Attack	Azure Portal	Interrupted	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication
4/19/2024, 9:55:08 AM	e68fc18b-7983-428e-ac5b-9d31ca0c9700	Phil Jones	Windows Sign In	Success	146.66.235.68	Jonkoping, Jonkopings Lan, SE	Not Applied	Single-factor authentication

Conditional Access

- Conditional Access är ett verktyg som hjälper oss hantera säkerhet för våra identiteter via Microsoft 365
- Tillåter oss att kontrollera inloggningsförfarandet genom en rad olika signaler

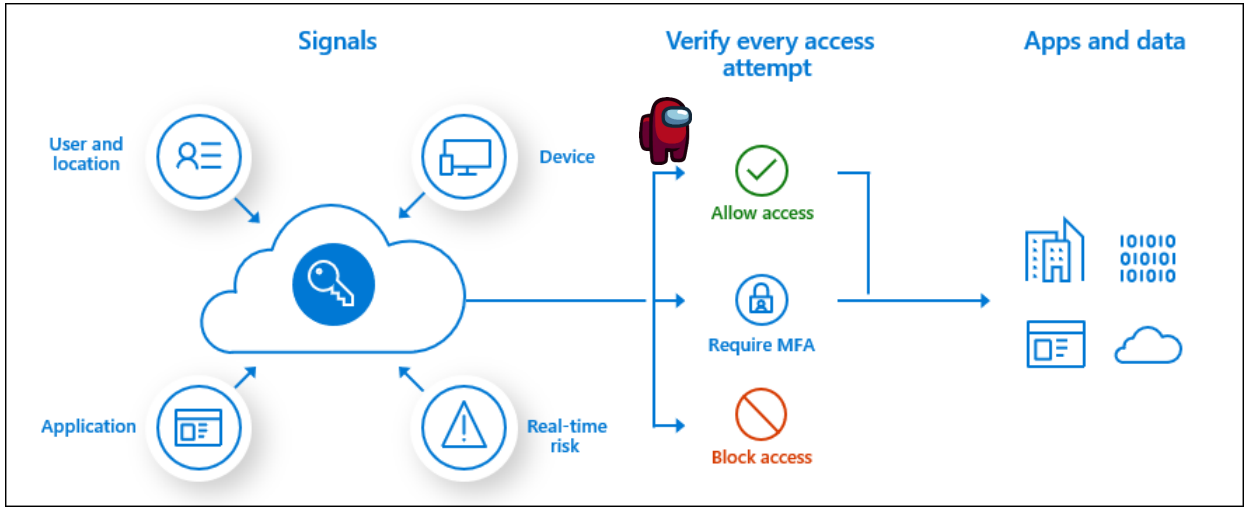
- Exempel på Signaler:
  - Användare eller Grupp
  - IP
  - Enhet
  - Applikation som försöker nås
  - Risk
- Exempel på Beslut som kan tas
  - Block
  - Tillåt
  - Kräv Multifaktor
  - Kräv Företagsansluten Enhet
  - Kräv Godkänn applikation

Conditional Access

- Normalt sett vill vi använda Conditional Access för att kontrollera åtkomsten till samtliga av våra molnresurser
- Conditional Access blir mer användbart desto fler system som har SSO mot Microsoft 365
- Användbart för både Privileged Access och User Access
- Exkluderinger i Conditional Access skall omfattas av någon annan regel. Exempelvis att ett servicekonto kan vara exkluderat om det kommer från en viss enhet.
- För att många system och applikationer i Microsoft 365 och Microsoft Azure går att integrera med Conditional Access går det att uppnå ett granulärt och säkert autentiseringsflöde
- Exempelvis:
  - För att komma åt känslig affärsdata måste användaren använda en Företagsansluten enhet med ett EDR system och MFA
  - För att administrera andra användare i Entra ID måste administratören använda en Specifik dator och autentisera sig 1 gång i timmen

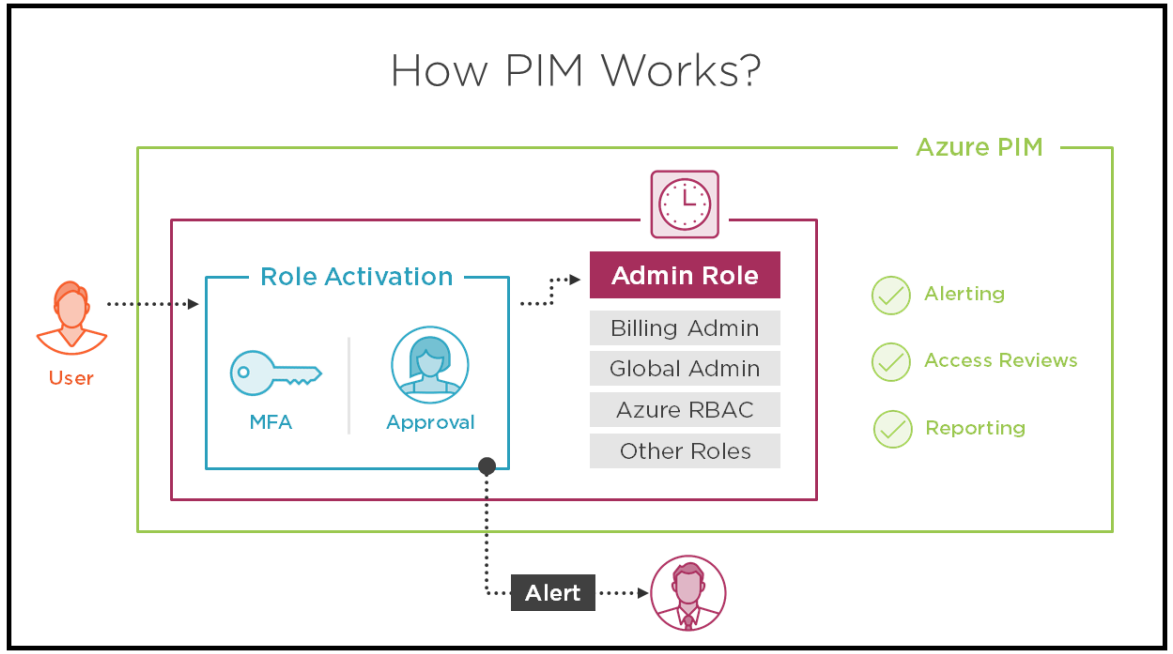
MFA (Multifaktorautentisering)

- MFA i Microsoft 365 uppnår vi med hjälp av Conditional Access
- Kardinalregeln i Conditional Access är MFA på alla användare alltid.
  - En M365 Tenant utan MFA för alla användare är som en DNS som svara rekursivt för internet.



Azure PIM

- Azure PIM är ett verktyg som hjälper oss hantera Privileged Access i Entra ID
- Det tillåter oss att aktivera en behörighet när vi behöver den och beskriva vad vi skall göra med behörigheten
- Följer metodiken för Just-In-Time
- Kan kräva Godkännande på känsliga roller



Access Strategy i Entra ID

- I Entra ID finns det 3 verktyg som kan hjälpa oss sätta implementera en bra Access Strategy
  - Conditional Access
  - Azure PIM
  - RBAC
- Kombinationen av att korrekt konfigurera de 3 verktygen gör att vi kan få en robust och säker Microsoft 365 Tenant för både User Access & Privileged Access
- Grundregler:
  - Principle of least privilege
  - Ingen behörighet skall vara permanent
  - Ingen autentisering skall ske utanför Conditional Access
  - Alla ska alltid använda MFA

Laboration

- Skapa en grundläggande Tiering-struktur i Active Directory
- Konfigurera en Microsoft 365 Tenant
- Konfigurera Azure AD Connect
- Administrera en användare
- Konfigurera Conditional Access
- Konfigurera Azure PIM
- Redovisas Nästa Vecka

JÖNKÖPING UNIVERSITY